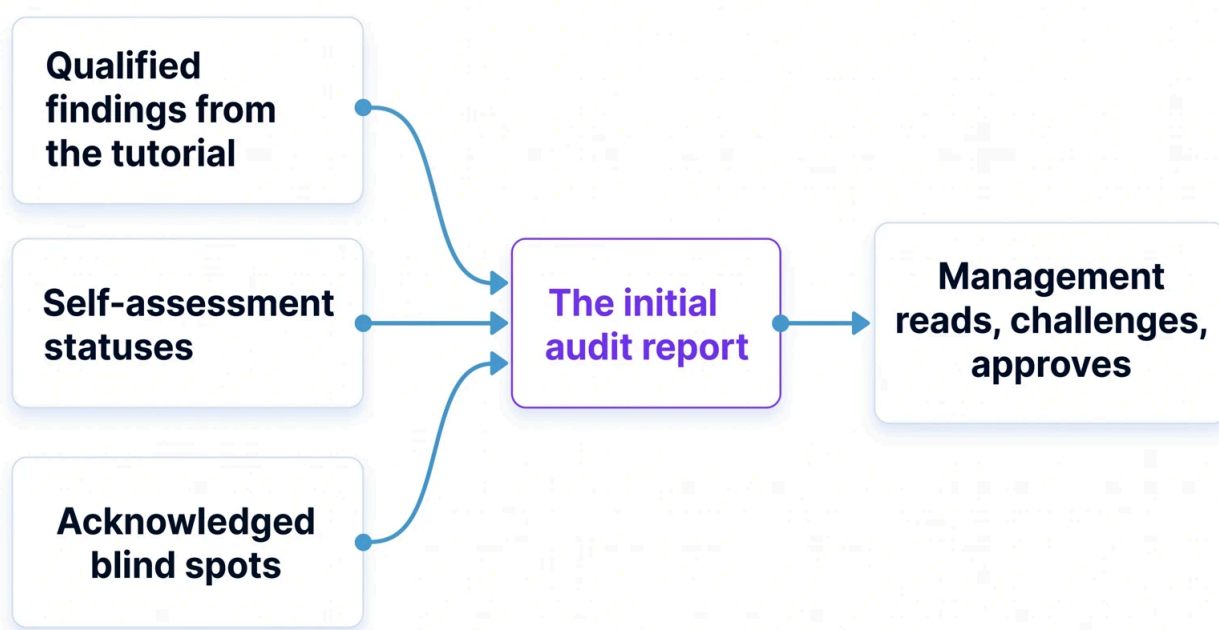


Initial audit report and Strategy note

✓ What the day measured becomes a document that commits



Session objectives

By the end of this lab, the file contains the MERIDIAN group's initial audit report, the exhibit that turns the day's findings into decision material, and the group's strategy note enriched with its fourth subsection. What is learned here:

- **Structure** an audit report: framing, summary, graded findings, recommendations, next steps
- **Formulate** a security recommendation that attaches to a finding and is expressed as a verifiable result, not as a sermon

- **Own** the limits of the exercise within the document itself: a self-assessment announces itself as such, or it lies
- **Articulate** the state of play with the group's trajectory, without encroaching on the risk assessment to come

Prerequisites

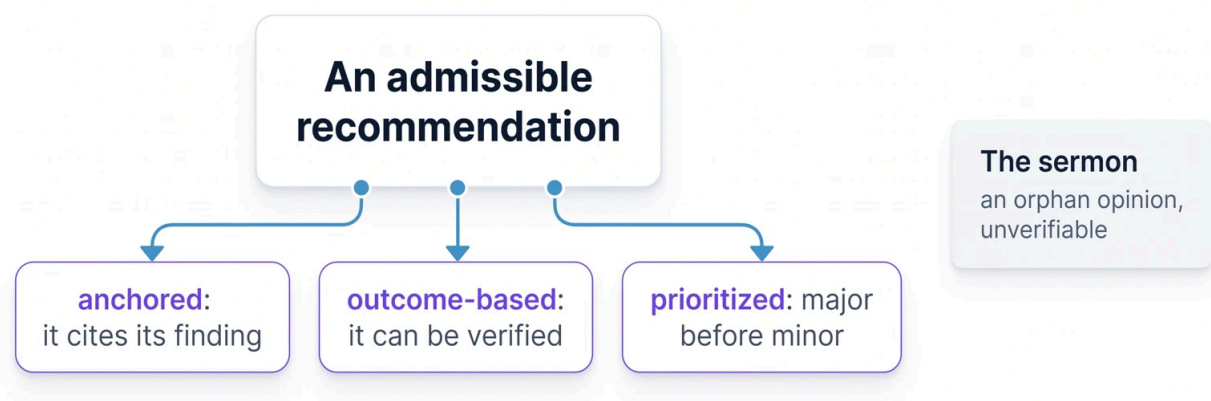
- The graded findings from midday's tutorial: compliant, major and minor nonconformities, observation. The report takes them up as they stand.
- The self-assessment from the previous lab: the statuses of the twelve requirements of the subsidiary under review, the per-theme summary, the list of deviations and blind spots.
- The group's strategy note, begun in session 1 and enriched since: context and target governance, critical assets, framework choice. The fourth stone is added to it.
- The cadence of the running thread: the group's roadmap, established in session 1, which the state of play now feeds.

✓ The audit report: the document that survives the meeting

The notion first, because it is the last piece of the session's vocabulary. The problem it solves: the day has produced sound findings, defended gradings, tooled statuses, and all of that lives in three sheets and a database; in two weeks, all that will remain is what has been written into a document that senior management can read, contest, then approve. An **audit report** is that document: the single, structured and dated account of an audit cycle, which sets out the framing, the method, the graded findings with their evidence, and the recommendations that flow from them. Its mechanics rest on a double loyalty: loyalty to the facts, every claim in the report traces to a piece of evidence; loyalty to the reader, senior management reads the summary and decides, the team reads the detail and acts. Its limit is that of the audit as a whole, said one last time: the report establishes and recommends, it decides nothing; the decision belongs to senior management and, for the operation of a system, to the authorizing authority whose role the tutorial showed.



And the **security recommendation**, since it is what gives the report its use value: it is the action the auditor proposes against a finding, expressed as a verifiable result, prioritized, and leaving the auditee the choice of means. Three disciplines separate it from the sermon. It attaches: each recommendation cites its finding, an orphan recommendation is an opinion. It is expressed as a result: "the subsidiary's administration accesses require MFA" can be verified, "strengthen password awareness" cannot. It is prioritized: the reader must know where to start, and today this hierarchy rests on the grading of deviations, major before minor; the definitive prioritization, weighted by severity and likelihood, belongs to the risk assessment that begins in session 5, and the report will say so explicitly, because announcing the limits of one's prioritization is yet another way of being exact.



The group's template, the one the deliverable must follow:

Section	Expected content	Length
1. Framing	Scope, audit criteria (framework, framework PSSI, regulatory foundation), method, and the owned limits: a tooled self-assessment of the subsidiary under review, without independence, supplemented by the findings of the internal cycle of the four subsidiaries	A third of a page
2. Summary for decision	The state in five sentences: what holds, what breaks, what is unknown, what is urgent, what comes next	A third of a page
3. Graded findings	The table: finding, cited criterion, evidence, grading, with the compliants and the observation	One page
4. Recommendations	Prioritized by grading, each traced to its finding, expressed as a result	Half a page
5. Corrective action plan	The tutorial's SMART lines, corrections and corrective actions distinguished	Half a page
6. Blind spots and next steps	The owned "not assessed", the independent audit to schedule, the session 5 risk assessment, the authorization approach framed at midday for the system of the subsidiary under review	A third of a page

Acceptance criteria for the deliverable, applied as they stand: no grading changed between the tutorial and the report without written justification, because regrading at writing time, under the pressure of the result, is exactly

the complacency the day has taught to hunt down; every recommendation traced to a finding; section 6 not empty; the summary readable by someone who did not follow the day; and nowhere a risk rating, a severity or a quantified likelihood, which would not exist yet.

Exercise 1: prepare the security

✓ authorization of the exposed system of the subsidiary under review (15 minutes)

Each subsidiary operates a system exposed to external users: the appointment booking portal and the hosted HIS for Santé, the WMS and its exchanges with the pharmaceutical customer's shipping portal for Logistique, the learning portal for Éducation, the citizen services platform for Territoires. The approach concerns the system of the subsidiary under review most exposed to external users. The trigger differs: for Territoires, a client local authority, subject to the RGS whose first obligation, seen in session 3, is to conduct a security authorization, passes the requirement on to its operator through its delegation officer; for the other three, it is the question Executive Management asks at the end of the subsidiary pack (section 7), which finds no answer without a formal decision to operate. In both cases, the request reaches the Group CISO: prepare the authorization approach for the system.

Expected output: the framing sheet of the approach.

1. **Determine** the level of the approach: assess the system's criticality for the subsidiary and its external users, then its exposure to risk sources, and cross the two in the guide's matrix. Justify each assessment in one sentence.
2. **Compose** the authorization committee: who leads it, which profiles sit on it, and who does NOT decide there.
3. **Identify** the authorizing authority: who, at MERIDIAN, can pronounce this decision, and why neither the Group CISO nor the auditor can.
4. **Inventory** the exhibits of the authorization file that the group already owns thanks to sessions 1 to 3, those that today produces, and the one that will still be missing this evening.
5. **Anticipate** the opinion: given the findings of the subsidiary under review graded in exercise 1 and the missing exhibit, what honest opinion can the committee aim for in the short term, and with what target authorization duration?

Exercise 2: write the initial audit report (25 minutes)

All the material exists: the framing comes from the previous lab, the findings and gradings from the tutorial, the statuses and blind spots from the self-assessment. Writing, here, means assembling without betraying.

1. **Write** the complete report, sections 1 to 6, keeping to the template and the acceptance criteria.
2. **Trace** each recommendation to its finding by its reference, with one word in parentheses at the end of the line.
3. **Reread** the summary on its own, asking whether the Chief Executive Officer, who did not live through the day, can decide with these five sentences; if a sentence presupposes a memory of the tutorial, it must be rewritten.

Exercise 3: repair three recommendations (5 minutes)

A hurried writer produced the following three recommendations. All of them are inadmissible in the sense of the three disciplines.

No.	Recommendation received
R1	"Great care must be taken with password management in all subsidiaries."
R2	"Deploy a latest-generation SIEM to solve the logs problem."
R3	"Supplier security must become an absolute priority for the group."

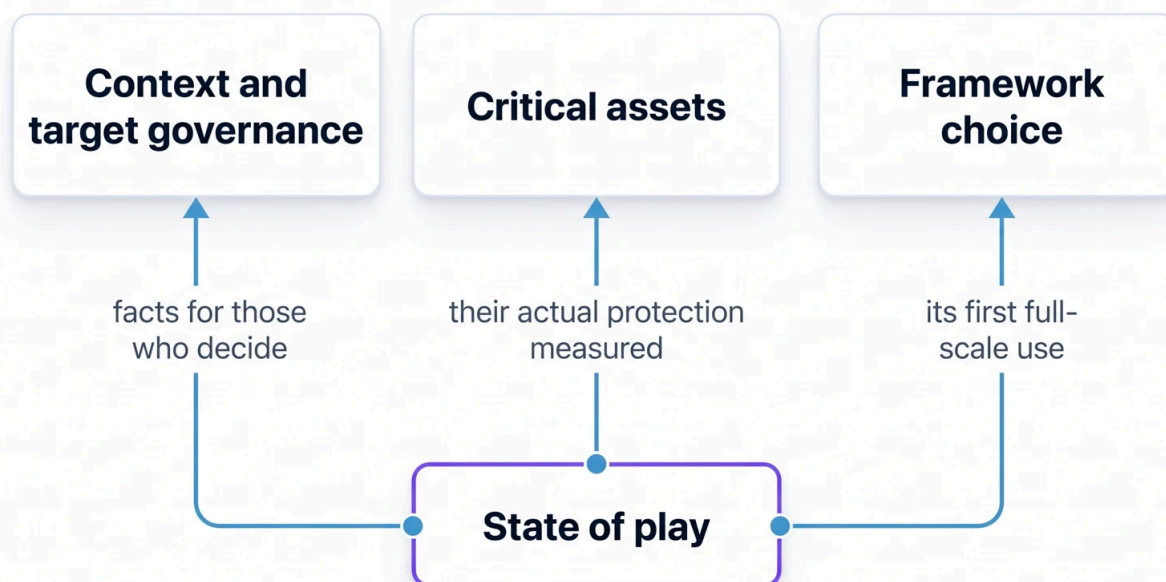
1. **Diagnose** for each one the discipline violated: attachment, verifiable result, or hierarchy.
2. **Rewrite** each one as an admissible recommendation, attached to a finding from the day.

Strategy note (15 minutes)

Last quarter of an hour, the module's ritual: the group's strategy note gains its subsection for the session, the fourth. A "State of play" subsection is added, half a page at most, which copies NOTHING from the audit report: the note carries the group's trajectory, not the evidence file. What it contains: the fact that a measured state of play

now exists, against which framework it was conducted and on what scope; the shape of the result in one sentence, written fresh, along the lines of “documented foundations, unproven application, identified blind spots”; and what this state commits for the rest of the trajectory, the risk assessment opening in session 5 and the authorization approach framed for the system of the subsidiary under review.

The articulation with the existing text is the real marking criterion. The “context and target governance” subsection from session 1 established who decides: the state of play is what will allow those decision-makers to decide on facts, and one sentence must say so. The “critical assets” subsection from session 2 established what matters: the state of play has just measured the actual protection of part of those assets. The “framework choice” subsection from session 3 established the yardstick: the state of play is its first full-scale use, and the roadmap established in session 1 gains here its first measured milestone. The document's constraints, to keep in mind: three pages at most for the whole, nothing gets deleted, and the exercise counts for 10 points in the module's marking scheme. If the addition overflows, tighten the new subsection, not the previous ones.



And to close the session, the sentence that hands it on: the initial audit report and its graded deviations enter, in session 5, the security baseline of the risk assessment's framing, and they will serve as point zero for continuous improvement when session 9 brings the system to life; what the group has just measured, it can no longer ignore, and that was exactly the point.



Answer keys and assessment criteria – cliquer pour révéler